



# HACKTHEBOX

## Compromised Writeup



25<sup>th</sup> January 2023

Prepared by: VivisGhost

Machine Author: Abdelrhman

Difficulty: **Easy**

## Scenario

Our Security Operations Center (SOC) has detected unusual and potentially malicious network activity. As a security analyst, your task is to investigate the suspicious traffic, identify the root cause, and recommend appropriate remediation steps.

## Artifacts Provided

- compromized.zip -

*f6d51e9d768a0940aa8c484a3e38b8a19de300cae30d2a04822a960cd09c2ca3*

```
[vivi$ghost@HackTheBox]-[~/Compromised]  
$sha256sum compromised.zip  
f6d51e9d768a0940aa8c484a3e38b8a19de300cae30d2a04822a960cd09c2ca3  compromised.zip
```

## Skills Learnt

- Network traffic analysis
- Utilizing threat intelligence feeds to validate findings

## Tags

- Incident response
- Network forensics

## Initial Analysis

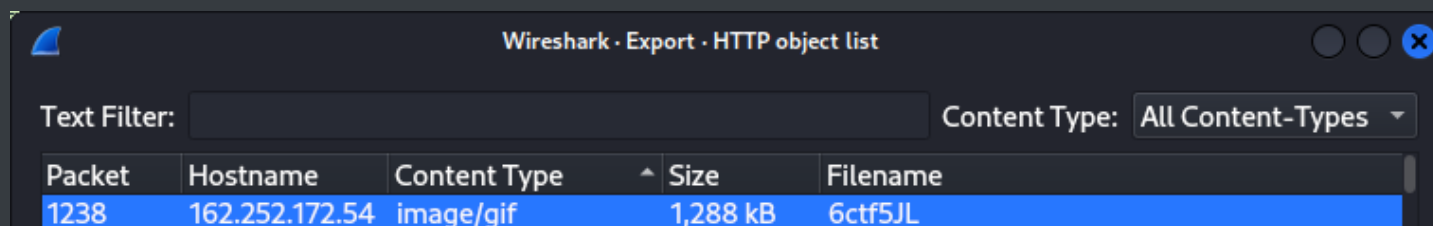
Upon inspecting the contents of `compromised.zip` (password: `hacktheblue`), we find a PCAP file containing the network capture for the incident.

```

[vivisghost@HackTheBox]--[~/Compromised]
$unzip -l compromised.zip
Archive:  compromised.zip
  Length      Date    Time    Name
-----
11772444  2023-05-18 13:59    capture.pcap
-----
11772444                      1 file

```

Opening the pcap up in wireshark and going to File -> Export Objects -> http we extract a suspicious file for further investigation.



The image shows a screenshot of the 'Wireshark - Export - HTTP object list' window. It has a 'Text Filter' field and a 'Content Type' dropdown menu set to 'All Content-Types'. Below is a table with the following data:

| Packet | Hostname       | Content Type | Size     | Filename |
|--------|----------------|--------------|----------|----------|
| 1238   | 162.252.172.54 | image/gif    | 1,288 kB | 6ctf5JL  |

Running the file command we can see it is a DLL.

```

[vivisghost@HackTheBox]--[~/Compromised]
$file 6ctf5JL
6ctf5JL: PE32 executable (DLL) (GUI) Intel 80386, for MS Windows, 6 sections

```

Calculate the SHA256 hash of the file.

```
[X]-[vivisghost@HackTheBox]-[~/Compromised]
$sha256sum 6ctf5JL
9b8ffdc8ba2b2caa485cca56a82b2dcbd251f65fb30bc88f0ac3da6704e4d3c6 6ctf5JL
```

Looking this hash up in VirusTotal we can see that it is probably malicious.

58 / 72

Community Score

58/72 security vendors flagged this file as malicious

Reanalyze Similar More

9b8ffdc8ba2b2caa485cca56a82b2dcbd251f65fb30bc88f0ac3da6704e4d3c6

6ctf5JL

Size1.23 MB

Last Analysis Date2 days ago

DLL

pedll

overlay

spreader

detect-debug-environment

persistence

checks-user-input

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY4

Crowdsourced YARA rules

Matches rule win\_pikabot\_auto from ruleset win\_pikabot\_auto at https://malpedia.caad.fkie.fraunhofer.de/ by Felix Bilstein - yara-signator at cocacoding dot com

↳ Detects win.pikabot.

Matches rule Windows\_Trojan\_PikaBot\_8c6750b5 from ruleset Windows\_Trojan\_PikaBot at https://github.com/elastic/protectio

↳ PikaBot Payload

Matches rule PikaBot from ruleset PikaBot at https://github.com/kevoreilly/CAPEv2 by kevoreilly

↳ PikaBot Payload

Clicking on the Details tab we can get some more basic information on the DLL.

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY4

Basic properties

MD52bf6280ce1a1ec314e08b988ed8c8050

SHA-11be1785a3e4a1aeda89bc2a5b26df7edc7fe1430

SHA-2569b8ffdc8ba2b2caa485cca56a82b2dcbd251f65fb30bc88f0ac3da6704e4d3c6

Vhash116066655d7515156az4b7z4

Authentihash e454f5f048bf069fed97642f4ddc0d9bc555243f33cbf47631bc0e19e8841f39

Imphash510d7aad4c1c6fc834c5c4ca7f484f8a

Rich PE header hash0353aeb37d381e043807049cda3e8770

SSDEEP24576:tv+qtKbCGLovhM2he3og6p6tOs1CTvmO4Kr5x+1kxjq0cnczy:M5CPjKjLCTvm0oqxdrv

TLSH T12E55AF52BDD0BB5BC37907BB49EE9D20277A998B7E372723724A6D3149281027F4181F

File typeWin32 DLL executable windows win32 pe pedll

MagicPE32 executable (DLL) (GUI) Intel 80386, for MS Windows

TrIDWin32 Executable MS Visual C++ (generic) (48.8%) Win64 Executable (generic) (16.4%) Win32 Dynamic Link Library (generic) (10.2%) Win16 NE executable (generic) (1.2%)

DetectItEasyPE32 Compiler: EP:Microsoft Visual C/C++ (2013) [DLL32] Compiler: Microsoft Visual C/C++ (19.28.30038) [C] Linker: Microsoft Linker (14.00.24245) Toolset: Microsoft (14.00.24245)

MagikaPEBIN

File size1.23 MB (1288212 bytes)

History

Creation Time2023-05-17 09:38:43 UTC

First Seen In The Wild2023-05-19 14:01:21 UTC

First Submission2023-05-17 19:04:23 UTC

Last Submission2024-10-29 19:51:33 UTC

Last Analysis2024-11-11 11:45:03 UTC

This is a good start for our initial analysis, we can now continue on trying to solve the questions.

## Questions

1. What is the IP address used for initial access?

We found this answer in our initial analysis when checking out the `6ctf5JL` file.

**Answer:** `162.252.172.54`

2. What is the SHA256 hash of the malware?

**Answer:** `9b8ffdc8ba2b2caa485cca56a82b2dcbd251f65fb30bc88f0ac3da6704e4d3c6`

3. What is the Family label of the malware?

We found this information on VirusTotal during the initial analysis.

**Answer:** `Pikabot`

4. When was the malware first seen in the wild (UTC)?

This detail was retrieved from VirusTotal.

**Answer:** `2023-05-19 14:01:21`

5. The malware used HTTPS traffic with a self-signed certificate. What are the ports, from smallest to largest?

To identify the self-signed certificates for this packet capture, we used two approaches.

1. Investigate the PCAP for `tls.handshake.type == 11`.
2. Cross-reference threat-hunting feeds to confirm associated IOCs.

When examining the PCAP we looked for instances where the `issuer` and `subject` were identical, indicating a self-signed certificate.

capture.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tls.handshake.type == 11

| No.              | Time            | Source | Source Port  | Destination | Destination Port | Protocol | Length | Leftover Info                                       |
|------------------|-----------------|--------|--------------|-------------|------------------|----------|--------|-----------------------------------------------------|
| 13 0.624758      | 184.168.98.68   | 443    | 172.16.1.191 | 51218       | TLSv1.2          | 1438     |        | Certificate, Certificate Status                     |
| 1249 231.376008  | 45.85.235.39    | 2078   | 172.16.1.191 | 51220       | TLSv1.2          | 838      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1294 232.661089  | 132.148.79.222  | 2222   | 172.16.1.191 | 51227       | TLSv1.2          | 736      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1353 743.698929  | 94.199.173.6    | 2222   | 172.16.1.191 | 51242       | TLSv1.2          | 878      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1443 1256.349509 | 184.244.42.1    | 443    | 172.16.1.191 | 51269       | TLSv1.2          | 683      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1463 1511.099246 | 129.80.164.200  | 32999  | 172.16.1.191 | 51262       | TLSv1.2          | 808      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1525 1768.449141 | 129.153.135.83  | 2078   | 172.16.1.191 | 51268       | TLSv1.2          | 808      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1551 2023.673048 | 193.122.200.171 | 2078   | 172.16.1.191 | 51271       | TLSv1.2          | 844      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1612 2280.688618 | 144.172.126.136 | 2222   | 172.16.1.191 | 51275       | TLSv1.2          | 748      |        | Certificate, Server Key Exchange, Server Hello Done |
| 6585 2538.229879 | 129.153.22.231  | 32999  | 172.16.1.191 | 51280       | TLSv1.2          | 872      |        | Certificate, Server Key Exchange, Server Hello Done |
| 9498 2793.432073 | 129.213.54.49   | 2078   | 172.16.1.191 | 51291       | TLSv1.2          | 847      |        | Certificate, Server Key Exchange, Server Hello Done |
| 9522 3048.906369 | 45.85.235.39    | 2078   | 172.16.1.191 | 51308       | TLSv1.2          | 754      |        | Certificate, Server Key Exchange, Server Hello Done |

version: v3 (2)  
serialNumber: 0x5651c79bfe0a17bc97bcb437c0f3ec25f7f6ec5  
signature (sha256WithRSAEncryption)

issuer: rdnSequence (0)  
rdnSequence: 6 items (id-at-commonName=votation.bzh,id-at-localityName=Pyopneumopericardium, id-at-countryName=US)  
rdnSequence item: 1 item (id-at-countryName=US)  
rdnSequence item: 1 item (id-at-stateOrProvinceName=KI)  
rdnSequence item: 1 item (id-at-organizationName=Unearred Inc.)  
rdnSequence item: 1 item (id-at-organizationalUnitName=Undelightful)  
rdnSequence item: 1 item (id-at-localityName=Pyopneumopericardium)  
rdnSequence item: 1 item (id-at-commonName=votation.bzh)

validity  
notBefore: utcTime (0)  
utcTime: 2023-05-14 08:36:52 (UTC)  
notAfter: utcTime (0)  
utcTime: 2024-05-13 08:36:52 (UTC)

subject: rdnSequence (0)  
rdnSequence: 6 items (id-at-commonName=votation.bzh,id-at-localityName=Pyopneumopericardium, id-at-countryName=US)  
rdnSequence item: 1 item (id-at-countryName=US)  
rdnSequence item: 1 item (id-at-stateOrProvinceName=KI)  
rdnSequence item: 1 item (id-at-organizationName=Unearred Inc.)  
rdnSequence item: 1 item (id-at-organizationalUnitName=Undelightful)  
rdnSequence item: 1 item (id-at-localityName=Pyopneumopericardium)  
rdnSequence item: 1 item (id-at-commonName=votation.bzh)

subjectPublicKeyInfo  
extensions: 3 items  
Extension (id-ce-subjectKeyIdentifier)  
Extension (id-ce-authorityKeyIdentifier)  
Extension (id-ce-basicConstraints)  
algorithmIdentifier (sha256WithRSAEncryption)

Frame (838 bytes) Reassembled TCP (1520 bytes)

Packets: 39106 · Displayed: 32 (0.1%) Profile: Default

Compare that to this DigiCert signed certificate for Twitter.

capture.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

tls.handshake.type == 11

| No.              | Time            | Source | Source Port  | Destination | Destination Port | Protocol | Length | Leftover Info                                       |
|------------------|-----------------|--------|--------------|-------------|------------------|----------|--------|-----------------------------------------------------|
| 13 0.624758      | 184.168.98.68   | 443    | 172.16.1.191 | 51218       | TLSv1.2          | 1438     |        | Certificate, Certificate Status                     |
| 1249 231.376008  | 45.85.235.39    | 2078   | 172.16.1.191 | 51220       | TLSv1.2          | 838      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1294 232.661089  | 132.148.79.222  | 2222   | 172.16.1.191 | 51227       | TLSv1.2          | 736      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1353 743.698929  | 94.199.173.6    | 2222   | 172.16.1.191 | 51242       | TLSv1.2          | 878      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1443 1256.349509 | 184.244.42.1    | 443    | 172.16.1.191 | 51269       | TLSv1.2          | 683      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1463 1511.099246 | 129.80.164.200  | 32999  | 172.16.1.191 | 51262       | TLSv1.2          | 808      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1525 1768.449141 | 129.153.135.83  | 2078   | 172.16.1.191 | 51268       | TLSv1.2          | 808      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1551 2023.673048 | 193.122.200.171 | 2078   | 172.16.1.191 | 51271       | TLSv1.2          | 844      |        | Certificate, Server Key Exchange, Server Hello Done |
| 1612 2280.688618 | 144.172.126.136 | 2222   | 172.16.1.191 | 51275       | TLSv1.2          | 748      |        | Certificate, Server Key Exchange, Server Hello Done |
| 6585 2538.229879 | 129.153.22.231  | 32999  | 172.16.1.191 | 51280       | TLSv1.2          | 872      |        | Certificate, Server Key Exchange, Server Hello Done |
| 9498 2793.432073 | 129.213.54.49   | 2078   | 172.16.1.191 | 51291       | TLSv1.2          | 847      |        | Certificate, Server Key Exchange, Server Hello Done |
| 9522 3048.906369 | 45.85.235.39    | 2078   | 172.16.1.191 | 51308       | TLSv1.2          | 754      |        | Certificate, Server Key Exchange, Server Hello Done |

Certificate Length: 1731  
Certificate [truncated]: 308206f308205a7a0030201020210038c374505e15da77254d949ec56061e308d06092a86  
version: v3 (2)  
serialNumber: 8x038c374505e15da77254d949ec56061e  
signature (sha256WithRSAEncryption)

issuer: rdnSequence (0)  
rdnSequence: 3 items (id-at-commonName=DigiCert TLS RSA SHA256 2020 CA1,id-at-organizationName=DigiCert, Inc.)  
rdnSequence item: 1 item (id-at-countryName=US)  
rdnSequence item: 1 item (id-at-organizationName=DigiCert, Inc.)  
rdnSequence item: 1 item (id-at-commonName=DigiCert TLS RSA SHA256 2020 CA1)

validity  
notBefore: utcTime (0)  
utcTime: 2022-11-14 00:00:00 (UTC)  
notAfter: utcTime (0)  
utcTime: 2023-11-14 23:59:59 (UTC)

subject: rdnSequence (0)  
rdnSequence: 5 items (id-at-commonName=twitter.com,id-at-organizationName=Twitter, Inc.,id-at-stateOrProvinceName=California)  
rdnSequence item: 1 item (id-at-stateOrProvinceName=California)  
rdnSequence item: 1 item (id-at-localityName=San Francisco)  
rdnSequence item: 1 item (id-at-organizationName=Twitter, Inc.)  
rdnSequence item: 1 item (id-at-commonName=twitter.com)

subjectPublicKeyInfo  
extensions: 10 items  
Extension (id-ce-authorityKeyIdentifier)  
Extension (id-ce-subjectKeyIdentifier)  
Extension (id-ce-subjectAltName)  
Extension (id-ce-keyUsage)  
Extension (id-ce-extendedKeyUsage)

Frame (683 bytes) Reassembled TCP (2967 bytes)

Packets: 39106 · Displayed: 32 (0.1%) Profile: Default

Now having an idea of what we are looking for in the PCAP we can compare these findings to threat intelligence.

Taking a look from this GitHub repository we can see some similar IPs.

```
https://github.com/pr0xylife/Qakbot/blob/main/Qakbot_BB28_Pikabot_17.05.2023.txt
```

```
399      .dll distro
400
401      http://162.252.172.54/9GQ5A8/95Lo909fj
402      http://158.255.213.181/miR/FeHxa0iM
403      http://149.154.158.91/Xnd/nhvrYBHms11R
404
405      *****
```

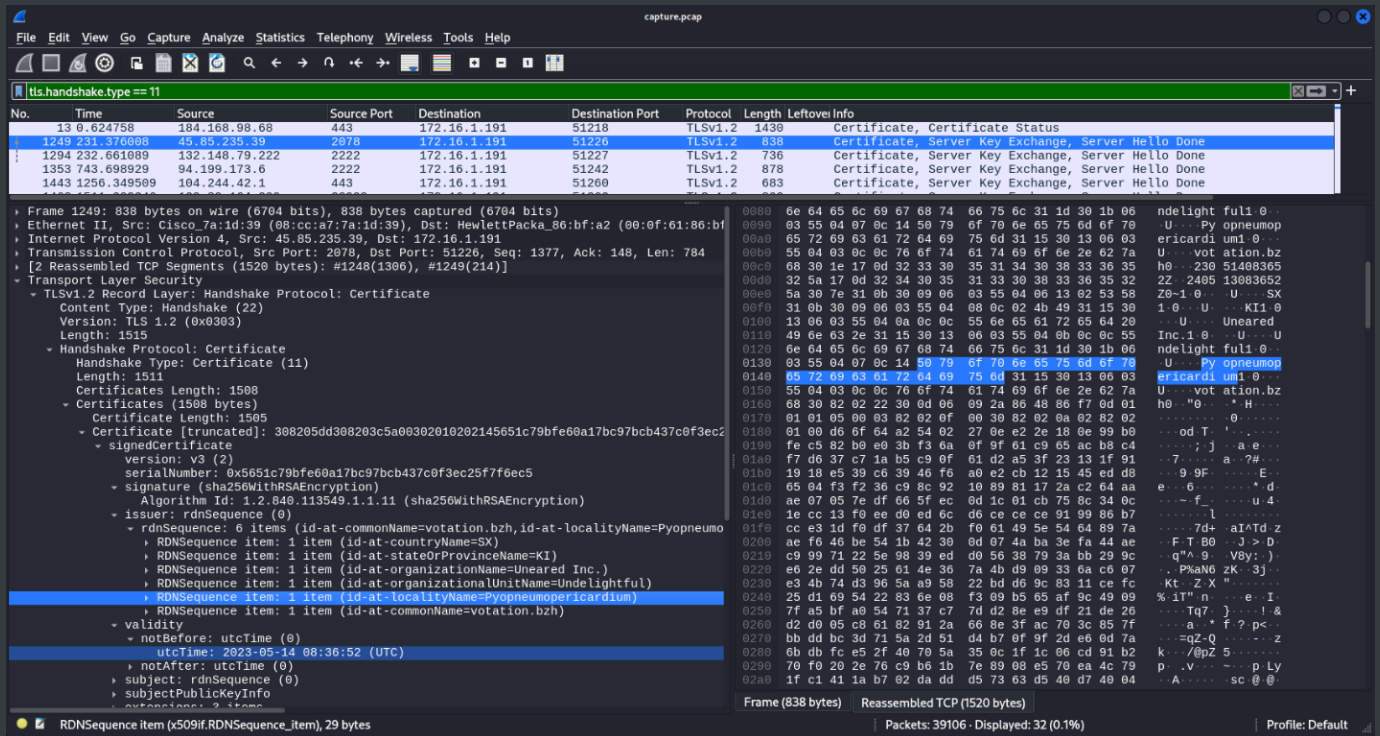
```
407      c2's
408
409      45.85.235.39:2078
410      94.199.173.6:2222
411      129.153.135.83:2078
412      129.153.22.231:32999
```

Looking over the PCAP again we can see the IPs and ports used.

**Answer:** 2078, 2222, 32999

6. What is the id-at-localityName of the self-signed certificate associated with the first malicious IP?

Similar to the previous question, we checked the packets in the PCAP file and validated this information with threat intelligence sources.



```

60 SELF-SIGNED CERTIFICATE FOR PIKABOT HTTPS SERVER AT 45.85.235[.]39 PORT 2078:
61
62 - Issuer:
63   -- id-at-countryName=SX
64   -- id-at-stateOrProvinceName=KI
65   -- id-at-organizationName=Unear Inc
66   -- id-at-organizationalUnitName=Undelightful
67   -- id-at-localityName=Pyopneumopericardium
68   -- id-at-commonName=votation.bzh
69 - Validity:
70   -- notBefore=2023-05-14 08:36:52 (UTC)
71   -- notAfter=2024-05-13 08:36:52 (UTC)
72 - Subject: Same values as issuer fields
73

```

**Answer:** Pyopneumopericardium

7. What is the notBefore time(UTC) for this self-signed certificate?

This was answered in the previous question.

**Answer:** 2023-05-14 08:36:52 UTC

8. What was the domain used for tunneling?

We located the domain in both the PCAP file and Unit42's threat hunting GitHub. A final review of the threat intelligence information confirmed the domain has been observed in similar incidents.



capture.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

| No.   | Time        | Source       | Source Port | Destination  | Destination Port | Protocol | Length | Leftover Info                                                        |
|-------|-------------|--------------|-------------|--------------|------------------|----------|--------|----------------------------------------------------------------------|
| 37197 | 6656.958902 | 172.16.1.16  |             | 172.16.1.191 |                  | DNS      | 109    | Standard query response 0xea27 A ridoj4.26fa3eb6.dns.steasteel.net A |
| 37198 | 6657.006050 | 172.16.1.191 |             | 172.16.1.16  |                  | DNS      | 93     | Standard query 0x07db A ridoj4.26fa3eb6.dns.steasteel.net            |
| 37199 | 6657.006131 | 172.16.1.16  |             | 172.16.1.191 |                  | DNS      | 109    | Standard query response 0x07db A ridoj4.26fa3eb6.dns.steasteel.net A |
| 37200 | 6657.037882 | 172.16.1.191 |             | 172.16.1.16  |                  | DNS      | 93     | Standard query 0x8679 A ridoj4.26fa3eb6.dns.steasteel.net            |
| 37201 | 6657.037980 | 172.16.1.16  |             | 172.16.1.191 |                  | DNS      | 109    | Standard query response 0x8679 A ridoj4.26fa3eb6.dns.steasteel.net A |
| 37202 | 6657.069839 | 172.16.1.191 |             | 172.16.1.16  |                  | DNS      | 93     | Standard query 0x3175 A ridoj4.26fa3eb6.dns.steasteel.net            |
| 37203 | 6657.069935 | 172.16.1.16  |             | 172.16.1.191 |                  | DNS      | 109    | Standard query response 0x3175 A ridoj4.26fa3eb6.dns.steasteel.net A |
| 37204 | 6657.133145 | 172.16.1.191 |             | 172.16.1.16  |                  | DNS      | 93     | Standard query 0x7268 A ridoj4.26fa3eb6.dns.steasteel.net            |
| 37205 | 6657.133244 | 172.16.1.16  |             | 172.16.1.191 |                  | DNS      | 109    | Standard query response 0x7268 A ridoj4.26fa3eb6.dns.steasteel.net A |
| 37206 | 6657.179415 | 172.16.1.191 |             | 172.16.1.16  |                  | DNS      | 93     | Standard query 0x04b8 A ridoj4.26fa3eb6.dns.steasteel.net            |
| 37207 | 6657.179498 | 172.16.1.16  |             | 172.16.1.191 |                  | DNS      | 109    | Standard query response 0x04b8 A ridoj4.26fa3eb6.dns.steasteel.net A |
| 37208 | 6657.288588 | 172.16.1.191 |             | 172.16.1.16  |                  | DNS      | 93     | Standard query 0x61b9 A ridoj4.26fa3eb6.dns.steasteel.net            |
| 37209 | 6657.288696 | 172.16.1.16  |             | 172.16.1.191 |                  | DNS      | 109    | Standard query response 0x61b9 A ridoj4.26fa3eb6.dns.steasteel.net A |
| 37210 | 6657.433015 | 172.16.1.191 |             | 172.16.1.16  |                  | DNS      | 93     | Standard query 0x2b0f A ridoj4.26fa3eb6.dns.steasteel.net            |
| 37211 | 6657.543165 | 172.16.1.16  |             | 172.16.1.191 |                  | DNS      | 109    | Standard query response 0x2b0f A ridoj4.26fa3eb6.dns.steasteel.net A |
| 37212 | 6657.883412 | 172.16.1.191 | 51676       | 23.163.0.37  | 8080             | TCP      | 66     | 51676 → 8080 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK PERM   |
| 37213 | 6657.929065 | 23.163.0.37  | 8080        | 172.16.1.191 | 51676            | TCP      | 58     | 8080 → 51676 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460         |
| 37214 | 6657.929185 | 172.16.1.191 | 51676       | 23.163.0.37  | 8080             | TCP      | 54     | 51676 → 8080 [ACK] Seq=1 Ack=1 Win=65535 Len=0                       |
| 37215 | 6657.929451 | 172.16.1.191 | 51676       | 23.163.0.37  | 8080             | TCP      | 1514   | 51676 → 8080 [ACK] Seq=1 Ack=1 Win=65535 Len=1460                    |
| 37216 | 6657.929458 | 172.16.1.191 | 51676       | 23.163.0.37  | 8080             | TCP      | 598    | 51676 → 8080 [PSH, ACK] Seq=1461 Ack=1 Win=65535 Len=544             |

Frame 37210: 93 bytes on wire (744 bits), 93 bytes captured (744 bits) on interface 0  
 Ethernet II, Src: Hewlett-Packard\_86:bf:a2 (08:0f:61:86:bf:a2), Dst: Dell\_00:11:32:00:00:00  
 Internet Protocol Version 4, Src: 172.16.1.191, Dst: 23.163.0.37  
 User Datagram Protocol, Src Port: 49243, Dst Port: 53  
 Domain Name System (query)  
 Transaction ID: 0x2b0f  
 Flags: 0x0100 Standard query  
 Questions: 1  
 Answer RRs: 0  
 Authority RRs: 0  
 Additional RRs: 0  
 Queries  
 ridoj4.26fa3eb6.dns.steasteel.net. type A, class IN  
 [Response in: 37211]

Text item (item), 39 bytes

Packets: 39106 · Displayed: 39106 (100.0%) Profile: Default

<https://github.com/PaloAltoNetworks/Unit42-timely-threat-intel/blob/main/2023-05-17-IOCs-for-Pikabot-with-Cobalt-Strike.txt>

```

50 COBALT STRIKE ACTIVITY:
51
52 - [various prefixes].dns.steasteel[.]net - DNS traffic: tunneling via replies to DNS queries for this domain
53 - Note: The domain steasteel[.]net was registered on 2023-04-11
54

```

**Answer:** steasteel.net